

Business Requirements Specification

Project Title: Data Deletion Management System (DDMS)

Version: 1.0

Prepared for: [Your Organisation]

Prepared by: ChatGPT

Reference Law: Zimbabwe Data Protection Act [Chapter 11:22]

1. Purpose

The purpose of this system is to enable the organisation to manage the **deletion, erasure, retention, restriction, and proof of disposal of personal data** in a lawful, controlled, secure, and auditable manner.

The system must support compliance with the Act, including:

- the requirement that data be kept **no longer than necessary** for the purpose collected;
 - the data subject's right to **deletion of false or misleading data**;
 - controller obligations to ensure accuracy, lawful processing, and privacy;
 - security, accountability, and breach-related controls surrounding stored and deleted data.
-

2. Business Objective

The organisation requires a system that will: 1. Identify personal data eligible for deletion. 2. Process deletion requests from data subjects and internal users. 3. Enforce retention schedules and legal holds. 4. Maintain evidence that deletion was performed correctly. 5. Prevent unlawful deletion where records must be retained by law, contract, litigation, public interest, research, employment, or security grounds. 6. Reduce privacy risk caused by over-retention of personal information.

3. Background

The Act requires data controllers to ensure data is:

- adequate, relevant, and not excessive;
- accurate and up to date;
- retained in identifiable form for **no longer than necessary**.

It also grants the data subject rights including:

- access,
- objection,
- correction,

- deletion of false or misleading data.

Controllers must also implement technical and organisational security measures, notify the Authority of breaches, and demonstrate accountability.

4. Scope

4.1 In Scope

The system shall manage:

- personal data deletion requests;
- retention-based automatic deletion;
- soft delete and hard delete workflows;
- anonymisation/pseudonymisation where deletion is not legally possible;
- deletion approvals and exception handling;
- deletion of structured and unstructured records;
- deletion audit logs and compliance reporting;
- notification workflows to compliance, legal, and data owners;
- deletion across databases, files, archives, backups metadata, and integrated systems.

4.2 Out of Scope

- cybercrime investigation functionality;
 - customer analytics unrelated to deletion;
 - creation of legal regulations;
 - direct breach-response platform functionality, except deletion-related records and evidence.
-

5. Stakeholders

- **Data Protection Officer (DPO)**
 - **Compliance Team**
 - **Legal Team**
 - **IT Operations**
 - **Security Team**
 - **Business Data Owners**
 - **Customer Service / Privacy Desk**
 - **Data Subjects**
 - **Executive Management**
 - **Regulator / Authority** where applicable under notification, inspection, or compliance review.
-

6. Business Problem Statement

The organisation currently faces risk that:

- personal data is kept longer than necessary;
- deletion requests are handled manually and inconsistently;
- data is deleted in one system but remains in others;
- no proof exists to demonstrate lawful deletion;
- deletion may occur when data should be preserved for legal or operational reasons;
- the organisation cannot easily demonstrate compliance to the Authority.

This creates legal, reputational, operational, and privacy risk under the Act's retention, rights, security, and accountability provisions.

7. Assumptions

- The organisation is a **data controller** or acts on behalf of one.
 - Personal data exists in multiple business applications and repositories.
 - The organisation has or will define retention rules by data type.
 - Legal and compliance teams will define deletion exceptions.
 - Some data may need to be retained due to law, public interest, national security, legal claims, employment, research, or health-related exceptions under the Act.
-

8. High-Level Business Requirements

BR1. Data Discovery and Classification

The system must identify and classify personal data by:

- data subject;
- data category;
- sensitivity level;
- source system;
- purpose of processing;
- retention period;
- legal basis or exception.

BR2. Retention Management

The system must assign and enforce retention schedules so that personal data is not retained longer than necessary for its purpose.

BR3. Deletion Request Management

The system must allow submission, review, approval, rejection, and fulfilment of deletion requests from data subjects or authorised internal staff.

BR4. Validation of Deletion Eligibility

The system must determine whether data can be deleted immediately, must be retained, or should be restricted/anonymised instead.

BR5. Deletion Execution

The system must support:

- record-level deletion;
- bulk deletion;
- workflow-driven deletion;
- rule-based automatic deletion;
- deletion propagation across connected systems.

BR6. Exception and Legal Hold Management

The system must block deletion where records are under:

- litigation hold;
- investigation;
- statutory retention;
- contractual retention;
- public interest or security exceptions;
- research or health-related exceptions, where permitted by law.

BR7. Audit and Accountability

The system must keep an immutable audit trail showing:

- who requested deletion;
- legal basis reviewed;
- approval decision;
- date and time of action;
- records affected;
- deletion outcome;
- exception rationale.

BR8. Security and Access Control

The system must ensure only authorised users can view, approve, reject, or execute deletion actions, and must protect deletion logs and associated data with appropriate security measures.

BR9. Reporting and Compliance Monitoring

The system must produce reports for management, auditors, and the DPO on:

- pending deletion requests;
- completed deletions;
- overdue requests;
- exception cases;
- retention violations;
- deletion evidence.

BR10. Notification and Escalation

The system must notify relevant stakeholders when:

- deletion requests are received;
 - deadlines are approaching;
 - deletion fails;
 - exceptions are applied;
 - suspicious patterns indicate privacy or security risk.
-

9. Functional Requirements

9.1 Request Intake

The system shall:

- allow deletion requests via web portal, admin console, API, or service desk;
- capture requestor identity, subject identity, data scope, and reason;
- support requests by data subject, guardian, or authorised representative where applicable.

9.2 Identity Verification

The system shall:

- verify the identity of the requester before action;
- support enhanced verification for sensitive data;
- record verification evidence.

9.3 Case Management

The system shall:

- generate a unique case ID;
- assign ownership;
- track status from submission to closure;

- support comments, attachments, and evidence.

9.4 Eligibility Rules Engine

The system shall evaluate:

- whether the data is false or misleading;
- whether the retention period has expired;
- whether deletion is required by policy;
- whether deletion is blocked by legal or regulatory exception;
- whether anonymisation is a lawful alternative.

9.5 Deletion Workflow

The system shall support:

- soft delete for business review;
- hard delete for final erasure;
- logical delete where physical delete is not possible;
- anonymisation for analytical/historical uses where allowed;
- purge confirmation.

9.6 Linked-System Deletion

The system shall:

- identify all linked repositories containing the subject's data;
- orchestrate deletion across those systems;
- prevent orphaned records where necessary;
- reconcile results and flag failures.

9.7 Retention Automation

The system shall:

- calculate deletion due dates;
- run scheduled deletion jobs;
- pause deletion where a hold exists;
- alert owners before high-risk or bulk deletion.

9.8 Exception Handling

The system shall:

- record the legal/business reason for non-deletion;
- allow legal hold creation and removal;
- allow partial deletion where only some fields are eligible.

9.9 Audit Logging

The system shall log:

- user actions;
- approvals;
- rule decisions;
- deletion results;
- exception justifications;
- system errors.

9.10 Reporting

The system shall provide:

- dashboard views;
 - exportable compliance reports;
 - subject-level deletion history;
 - retention-expiry reports;
 - failed deletion exception reports.
-

10. Non-Functional Requirements

10.1 Security

The system must implement technical and organisational controls to protect data against unauthorised access, loss, alteration, or destruction.

Minimum requirements:

- role-based access control;
- MFA for privileged users;
- encryption in transit and at rest;
- tamper-evident logs;
- segregation of duties.

10.2 Availability

The system should be available during business-critical periods and support scheduled deletion jobs without significant downtime.

10.3 Performance

- Search and retrieve a subject deletion case within 3 seconds.
- Process single-record deletions in near real time.
- Support bulk deletion batches without service degradation.

10.4 Scalability

The solution must support growth in:

- users,
- requests,
- connected data sources,
- deletion volume,
- audit records.

10.5 Reliability

The system must ensure deletion jobs are restartable and recoverable after failure.

10.6 Auditability

The system must preserve a defensible audit trail for internal review and potential regulatory inspection.

10.7 Usability

The system should provide simple workflows for privacy, legal, and operational staff with minimal training.

11. Business Rules

1. Personal data shall not be kept in identifiable form longer than necessary for the purpose for which it was collected or further processed.
 2. A data subject may request deletion of false or misleading data.
 3. Data deletion must not occur where preservation is required by law, legal claims, public interest, employment obligations, security, health, research, or other recognised exceptions.
 4. All deletion actions must be approved according to delegated authority.
 5. Sensitive data deletion must require enhanced approval.
 6. Deletion must be logged and reportable.
 7. Backups may follow a deferred purge policy, but restored data must not reappear as active records without control.
 8. Where data cannot be deleted, access must be restricted and rationale recorded.
-

12. User Roles

- **Privacy Administrator:** manages requests and workflows.
- **DPO/Compliance Officer:** reviews and approves cases, monitors compliance.
- **Legal Reviewer:** places or releases legal holds.
- **System Administrator:** manages integrations and system configuration.
- **Business Owner:** validates business impact of deletion.
- **Auditor:** reviews evidence and logs.

- **Data Subject Portal User:** submits and tracks request status.
-

13. Key Use Cases

Use Case 1: Data Subject Requests Deletion

A customer submits a request to delete inaccurate or misleading personal data. The system verifies identity, checks eligibility, routes for approval, deletes eligible records, logs the action, and confirms completion.

Use Case 2: Automatic Deletion on Retention Expiry

The system identifies records past retention end-date and automatically deletes or anonymises them after validation.

Use Case 3: Deletion Blocked by Legal Hold

A deletion request is received, but the legal team has marked the record under investigation. The system blocks deletion, records the reason, and notifies the case owner.

Use Case 4: Sensitive Data Deletion

A request concerns health or biometric data. The system triggers enhanced approval and records the lawful handling pathway given the special protection of such data.

Use Case 5: Failed Deletion in Downstream System

The primary system deletes data, but a connected archive fails. The system raises an exception, logs it, and escalates for remediation.

14. Data Requirements

The system must store:

- subject identifiers;
- request details;
- system-of-record references;
- data categories;
- retention rules;
- legal hold flags;
- approval history;
- deletion outcome;
- audit logs;
- evidence artifacts.

The system should avoid storing unnecessary personal data itself and must follow data minimisation principles.

15. Integration Requirements

The system should integrate with:

- CRM systems
 - HR systems
 - finance systems
 - document repositories
 - email archives
 - database platforms
 - identity and access management tools
 - ticketing/workflow tools
 - security logging/SIEM tools
-

16. Risks

- Incomplete deletion across systems
 - Accidental deletion of records under lawful retention
 - Weak identity verification leading to fraudulent requests
 - Inadequate audit evidence
 - Poor mapping of retention rules
 - Conflict between business needs and compliance
 - Backup persistence creating reappearance risk
-

17. Controls and Mitigations

- approval workflow;
 - legal hold checks;
 - deletion simulation before execution;
 - periodic reconciliation scans;
 - immutable audit logs;
 - maker-checker control for high-risk deletions;
 - role-based access and MFA;
 - exception dashboards;
 - periodic compliance review by DPO.
-

18. Success Criteria

The system will be considered successful when:

- 100% of deletion requests are logged and traceable;
 - retention-based deletions occur automatically according to policy;
 - all deletion decisions are auditable;
 - exception handling is documented;
 - the organisation can demonstrate accountability to the Authority;
 - privacy risk from over-retention is materially reduced.
-

19. Acceptance Criteria

1. Users can submit, review, approve, reject, and close deletion requests.
 2. The system can enforce retention schedules.
 3. The system can prevent deletion when a hold exists.
 4. The system can produce deletion evidence reports.
 5. The system has access controls and audit logs.
 6. The system supports deletion across integrated repositories.
 7. The system supports data subject rights workflows relevant to deletion and correction.
-

20. Recommended Modules

For implementation, I'd recommend these modules:

- **Request Portal**
 - **Case Management**
 - **Retention Rules Engine**
 - **Deletion Orchestrator**
 - **Legal Hold Manager**
 - **Audit & Evidence Vault**
 - **Compliance Dashboard**
 - **Notification Engine**
 - **Integration Layer / APIs**
-

21. Suggested KPIs

- Average deletion request turnaround time
- % of requests completed within SLA
- % of records deleted on time after retention expiry
- % of failed deletions
- % of cases blocked due to legal holds

- number of manual interventions required
 - audit findings related to retention/deletion
 - number of systems integrated for deletion enforcement
-

22. Conclusion

This BRS defines a **Data Deletion Management System** that supports lawful erasure, retention enforcement, exception handling, and demonstrable compliance under the Zimbabwe Data Protection Act. It is especially anchored in the Act's requirements on:

- retention only as long as necessary,
- data subject deletion rights,
- security,
- accountability,
- controlled processing by data controllers.

One important note: the Act text expressly mentions deletion of **false or misleading data** and broader retention-limitation duties, rather than a broad standalone "right to erasure" phrased exactly like GDPR. So this BRS is strongest when positioned as a **deletion and retention compliance system**, not as an unrestricted erase-anything system.